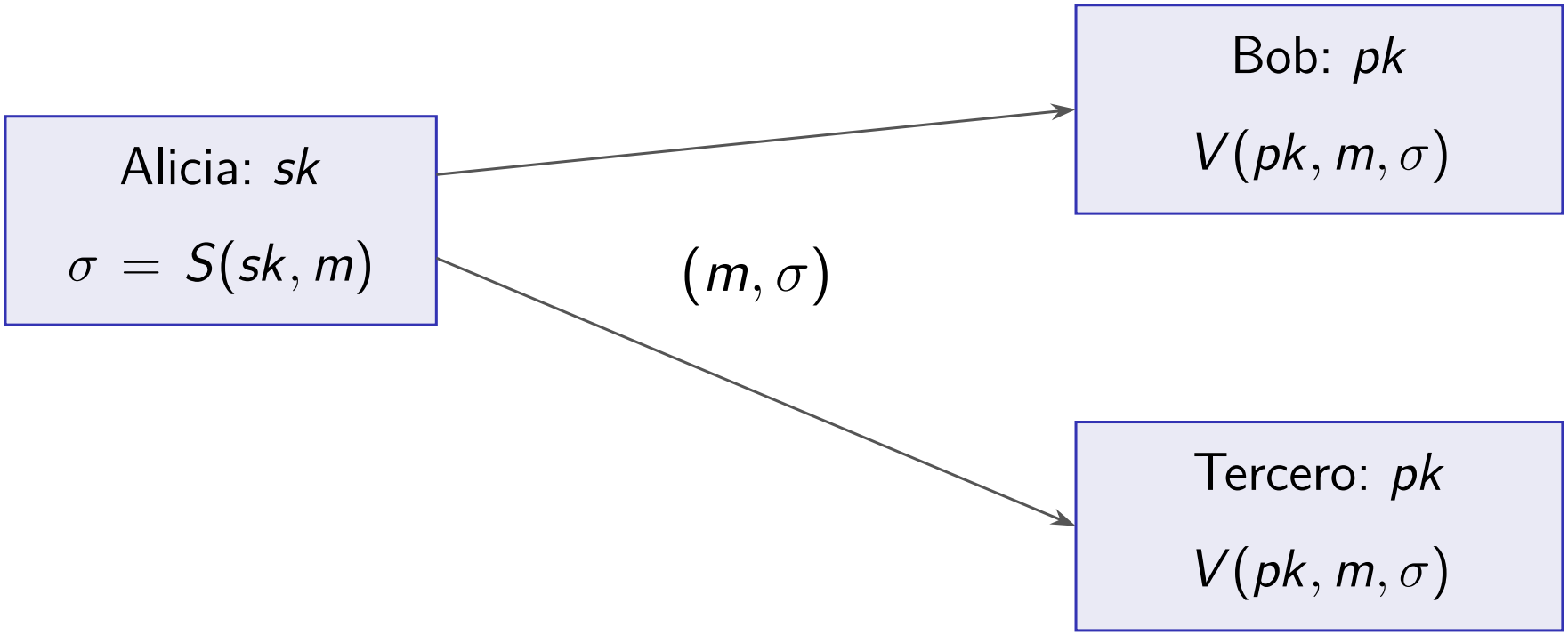
Firmas digitales



Universidad del Norte

Motivación

Suponga que Alicia ordena un automóvil rojo a Bob. Si después niega haberlo pedido, Bob necesita mostrar la orden a un tercero que pueda verificar su origen sin poder firmar en nombre de Alicia.

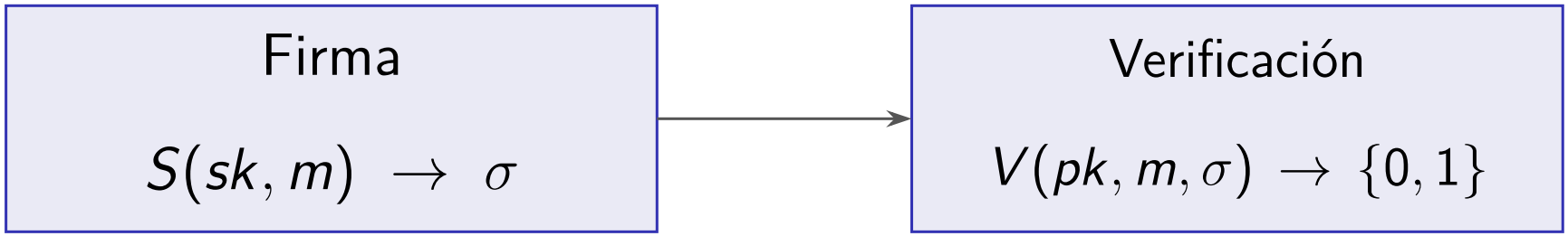


Bob y el tercero necesitan una llave pública auténtica de Alicia para atribuirle la firma.

Esquemas de firma digital

Un esquema de firma digital (G, S, V) consta de tres algoritmos: generación de llaves, firma y verificación.

$$(pk, sk) \quad \leftarrow \quad G(1^{\lambda})$$

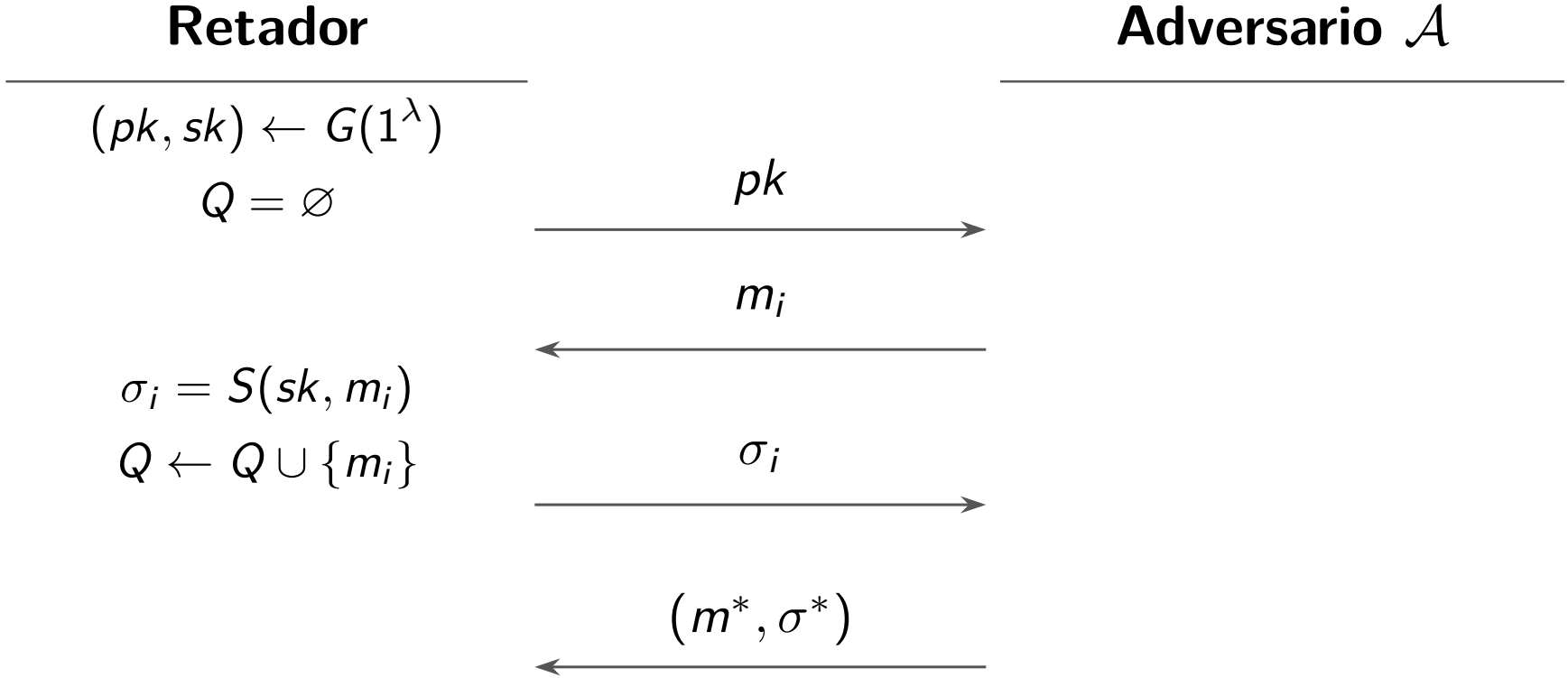


$$V(pk, m, S(sk, m)) \quad = \quad 1$$

El algoritmo G genera las llaves a partir del parámetro de seguridad λ. La correctitud exige que, para cualquier par generado y cualquier mensaje, una firma legítima sea aceptada.

Juego de seguridad de una firma digital

El adversario conoce pk y puede pedir firmas. Debe firmar un mensaje nuevo a partir de lo aprendido en esas consultas.



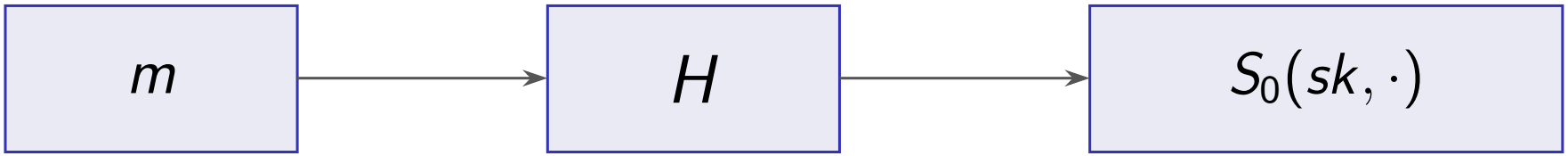
$$\text{Gana} \iff m^* \notin Q \ \wedge \ V(pk, m^*, \sigma^*) = 1$$

EUF-CMA exige que todo adversario eficiente gane con probabilidad despreciable.

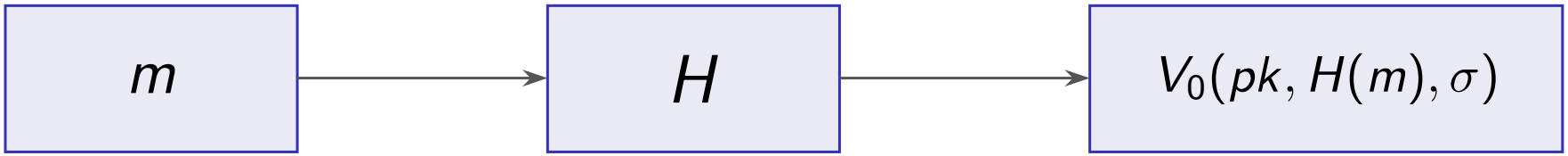
El paradigma hash-luego-firma

Suponga que (G, S_0, V_0) firma mensajes de longitud fija. Para admitir mensajes más largos, calculamos primero su hash y firmamos el resumen: $S(sk, m) = S_0(sk, H(m))$.

Firma



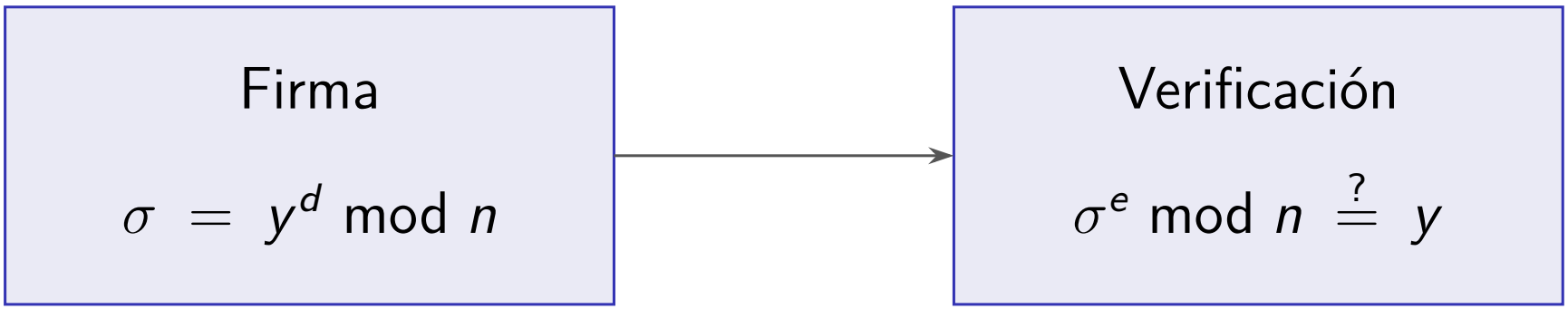
Verificación



El hash debe resistir colisiones: una firma del resumen también verificaría para otro mensaje que produjera ese mismo resumen.

Firmas basadas en RSA

Retomemos RSA. Sean p, q primos distintos, $n = pq$ y $ed \equiv 1 \pmod{\varphi(n)}$. Para firmar un representante y, aplicamos el exponente privado d; para verificar, usamos el exponente público e.



En el ejemplo didáctico tomamos $y = \text{int}(H(m)) \bmod n$. La identidad RSA permite recuperar y al elevar la firma a e.

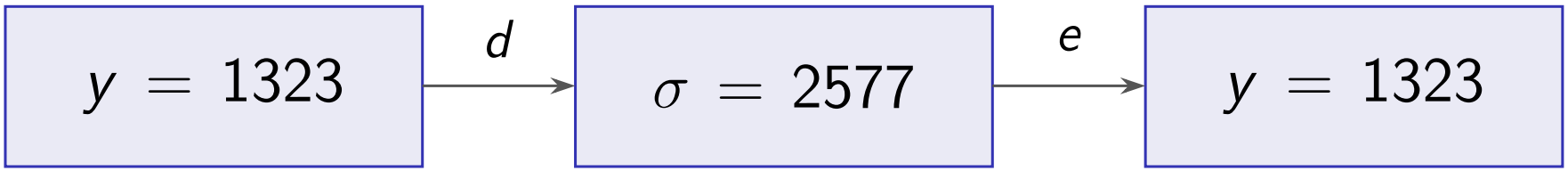
Esto explica la correctitud de la operación. Para obtener un esquema de firma seguro, también debemos especificar y analizar cómo se codifica el mensaje.

Un ejemplo con RSA

Tomemos parámetros pequeños para seguir las operaciones de firma y verificación.

$$p = 61, \quad q = 53, \quad n = 3233, \quad e = 17, \quad d = 2753$$

`orden de un automovil rojo`



$$17 \cdot 2753 = 1 + 15 \cdot 3120$$

Estos valores permiten comprobar las operaciones de RSA. Como el módulo 3233 se factoriza fácilmente, el ejemplo no ofrece seguridad.

Firma y verificación RSA-PKCS1-v1.5

RSA-PKCS1-v1.5 codifica el hash y su identificador antes de aplicar RSA. La verificación reconstruye esa codificación y comprueba el bloque completo.

Alicia: firma

$$EM = \text{Encode}(m)$$

$$\sigma = \text{int}(EM)^d \bmod n$$

Bob: verifica

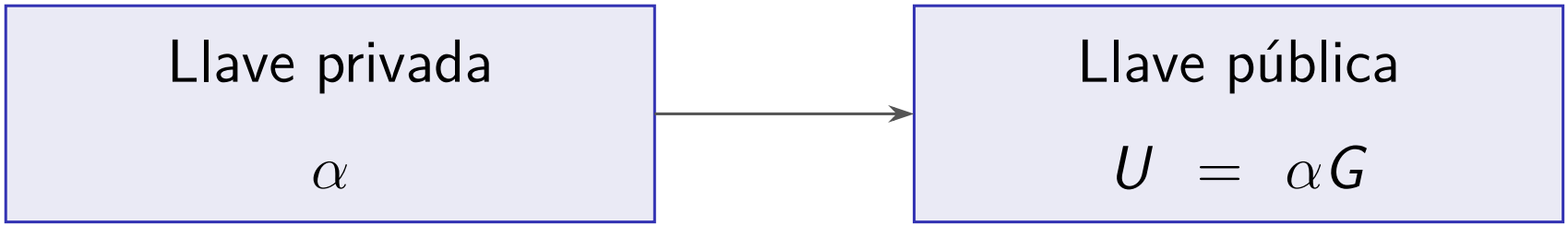
$$EM' = \text{Encode}(m)$$

$$y = \sigma^e \bmod n$$

Bob acepta si la firma tiene longitud y rango válidos, y los bytes de y coinciden con EM'. La biblioteca realiza estas comprobaciones.

Llaves y parámetros de ECDSA

Sea G un punto de orden primo q en una curva sobre $\mathbb{F}_p$. Alicia escoge una llave privada $\alpha \in \{1, \ldots, q-1\}$ y publica $U = \alpha G$.

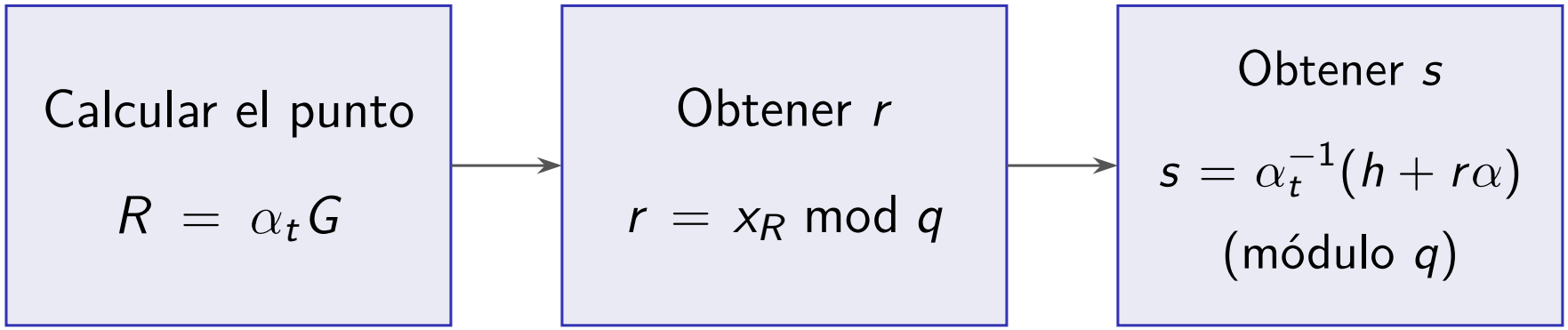


Para firmar sobre P-256, calculamos el resumen $h = \text{int}(\text{SHA256}(m))$ y generamos un nonce secreto e impredecible $\alpha_t \in \{1, \ldots, q-1\}$.

Las coordenadas se calculan módulo p; los escalares, módulo q. El nonce debe permanecer secreto y no reutilizarse para mensajes distintos.

Algoritmo de firma ECDSA

Con el nonce α_t, Alicia calcula el punto $R = (x_R, y_R) = \alpha_t G$. De su coordenada x_R obtiene r, y combina ese valor con el resumen y la llave privada para obtener s.

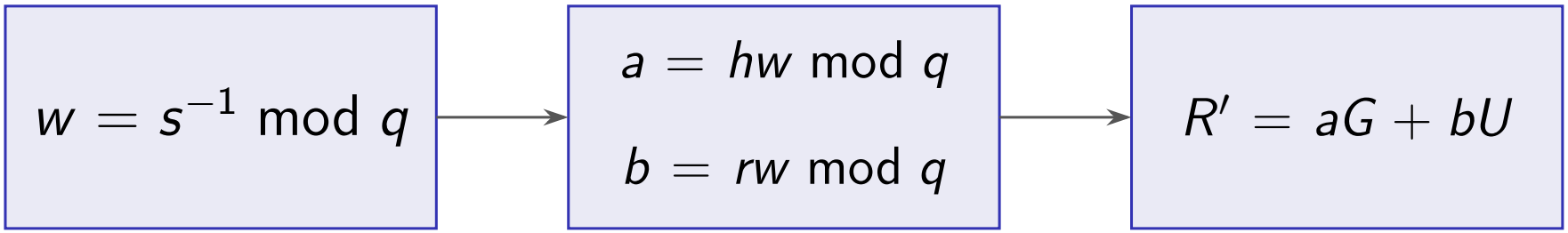


$$\sigma = (r, s)$$

La firma es el par (r, s). Si alguna componente es cero, se elige otro nonce y se repite el cálculo. Alicia envía el mensaje y la firma, y conserva secretos α y α_t.

Algoritmo de verificación ECDSA

Bob recibe m y (r, s), y dispone de una llave pública válida U. Primero comprueba que $1 \leq r, s \leq q - 1$; luego calcula el resumen h y el punto siguiente.



$$R' \neq \mathcal{O} \quad \wedge \quad x_{R'} \bmod q = r$$

Bob acepta si R' no es el punto al infinito y su coordenada satisface la igualdad. Si $R' = \mathcal{O}$, no hay coordenada afín que comparar.

Correctitud de ECDSA

Veamos por qué el punto calculado por Bob coincide con el que utilizó Alicia cuando la firma es legítima.

$$R' = s^{-1}hG + s^{-1}rU$$

$$U = \alpha G \implies R' = s^{-1}(h + r\alpha)G$$

$$s = \alpha_t^{-1}(h + r\alpha) \pmod{q} \implies R' = \alpha_t G = R$$

$$x_{R'} \bmod q = x_R \bmod q = r$$

Por tanto, una firma legítima satisface la comprobación del verificador. La dificultad de falsificar requiere un análisis de seguridad adicional.

Referencias

Definiciones y juegos: Boneh y Shoup.
https://toc.cryptobook.us/

Firmas RSA: RFC 8017.
https://www.rfc-editor.org/rfc/rfc8017

ECDSA: NIST FIPS 186-5.
https://doi.org/10.6028/NIST.FIPS.186-5

Curvas y parámetros: NIST SP 800-186.
https://doi.org/10.6028/NIST.SP.800-186